



Universiteit
Leiden
The Netherlands

Network Security

Lecture Handout

Eleftheria Makri

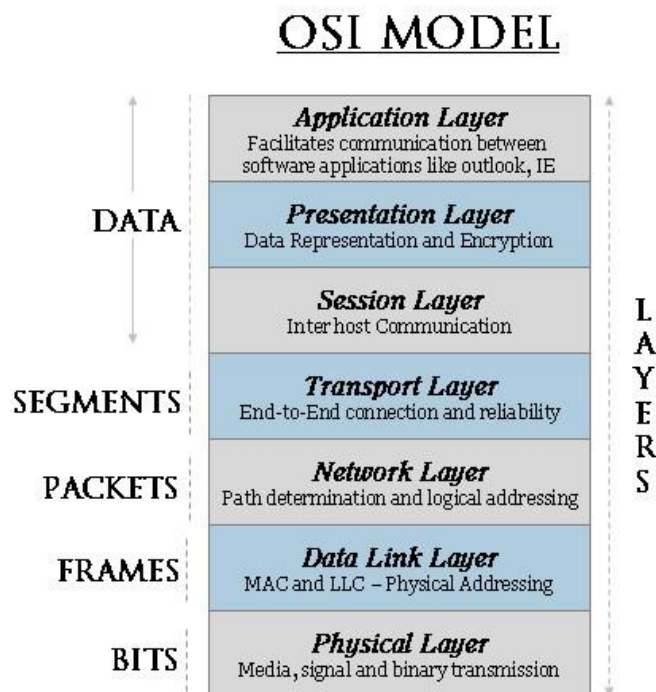
2025-2026

Secure Network Architecture and Design

Telecommunication and Network Security concerns the structures, transmission methods, transport formats, and security measures used to provide confidentiality, integrity, and availability for transmissions over private and public communication networks and media. Network security is often referred to as the cornerstone of IT security, since the network is one of the most central assets.

1. OSI and TCP/IP

The most commonly used network model, is the seven-layer OSI (Open System Interconnect) model, presented below. OSI is standardized under ISO/IEC 7498-1.



- **Physical Layer:** Bits (from data link layer) converted to (electrical) signals. **Includes:**
 - Physical topologies
 - Hardware: mostly cables, but also hubs and modems.
- **Data Link Layer:** Packets are transformed to error-free frames.
 - Uses HW addresses to transmit frames amongst physically connected devices
 - Divided into two sublayers:
 - Logical Link Control (LLC): Manages connections between two peers, providing error and flow control
 - Media Access Control (MAC): Transmits/Receives frames. Logical topologies and HW addresses are defined here.

- **Network Layer:** Moves information between two hosts that are NOT physically connected. Uses only logical addressing (i.e., no HW addresses in use), created when hosts are configured. The most important network layer protocol is the Internet Protocol (IP).
 - Internet Protocol (IP) main functions:
 - **Addressing** (IP of destination used until reached)
 - **Fragmentation** (subdivision of packets depending on their size)
It is a connectionless protocol (i.e., non error-free)
 - Routing Information Protocol (RIP): Uses distance vector algorithms to determine direction and distance to any link. Selects the path with the least hops.
 - **v1** (RFC 1058): Updates routing tables at programmable intervals. Prevents infinite loops by setting max hop count = 15.
 - **v2** (RFC 1723): Uses subnet mask and password authentication. Specifies the next hop address. Does not aggregate the routes on the network boundary.
 - Open Shortest Path First (OSPF): (v1 RFC 1131) Is based on shortest path first or link-state algorithms. Each router sends its own topography of the network. Advantage: smaller & more frequent updates (preventing routing loops). Disadvantage: Requires large amount of CPU and memory.
 - v2 (RFC 2328): Learning dynamically routes from other routers (advertisements). Routes are called Link State Advertisements (LSAs). Finds lowest cost paths.
 - Border Gateway Protocol (BGP): Replaces Exterior Gateway Protocol for fully decentralized routing. Achieves interdomain routing in TCP/IP networks mainly between ASs (Autonomous Systems). Updates only when hosts detect changes, and only the affected part of the table is re-sent. BGP-4 allows administrators to configure cost metrics based on policy statements.
 - Internet Control Message Protocol (ICMP): (RFC 792) Consists of two main categories of messages:
 - ICMP Error Messages
 - ICMP Query Messages.Important Functions:
 - Announce network Errors
 - Announce network congestion
 - Assist Troubleshooting
 - Announce Timeouts
- **Transport Layer:** End-to-end transport between hosts.
Important protocols:
 - **UDP** (User Datagram Protocol): connectionless unreliable protocol.
 - **TCP** (Transmission Control Protocol): connection-oriented reliable protocol (providing integrity). Divides information into segments and reassembles them in the correct order.
Guaranteed communication session via **TCP Three Way Handshake**.

- **Session Layer:** Analogous to a conversation between applications exchanging information.
Modes:

- (Full) Duplex
- Half Duplex
- Simplex

- **Presentation Layer:** Provides compatibility, by ensuring common format of data representation between peer applications.

Architecture:

- **Services:**
 - Data Conversion
 - Character code translation
 - Compression
 - Encryption/Decryption
- **Sublayers:**
 - CASE (Common Application Service Element)
 - SASE (Specific Application Service Element)

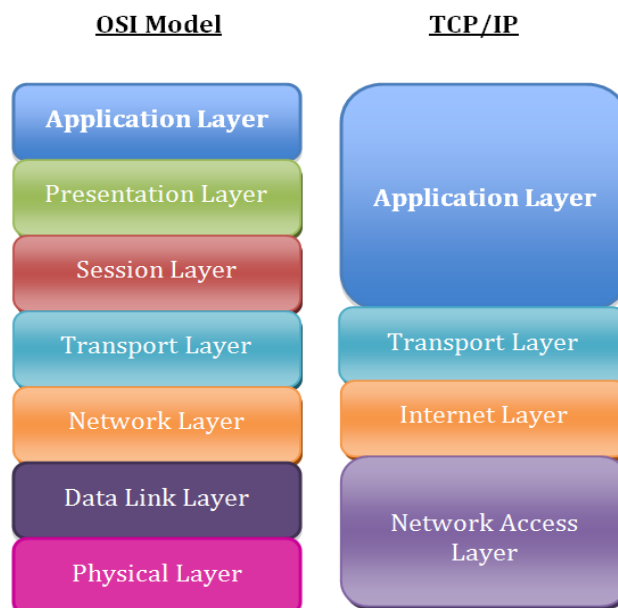
Important Protocols:

- Telnet (remote terminal access protocol)
- FTP (File Transfer Protocol) *in between layers 6 and 7*

- **Application Layer:** It is the application's portal to network services.

TCP/IP reference model

The TCP/IP reference model is very similar to the OSI model and it has been developed by the U.S. Department of Defence. The layers comprising the TCP/IP model and their correspondence to the OSI model is presented in the figure below.



2. Protocols and Services

Domain Name System (DNS)

DNS is one of the most prominent (and visible) network services to the user. Its role is to support the resolution of e-mail and www addresses. It is also a prominent target of attacks. Manipulating DNS can make possible to divert, intercept, or prevent the vast majority of end-user communications. It is robust, flexible and scalable, as it is based on a multi-tiered hierarchy for redundancy and security. If a DNS resolver goes offline, the integrity of the system as a whole is still maintained.

HTTP (Hypertext Transfer Protocol)

HTTP was originally a stateless version of FTP to support the exchange of information in Hypertext Markup Language. The standard port for http is 80/TCP. It offers no quality of service and no bi-directional communication. It does not support encryption, while authentication is simple username/password style.

HTTP Proxying:

- **Anonymizing proxies:** Used to avoid industrial espionage coming from the cleartext logged data on web servers
- **Open proxy servers:** Used to allow unrestricted access to GET commands. Thus, they are used for attacks, or for obscuring the origin of illegitimate requests.
- **Content filtering:** Used for logging or blocking traffic that is assumed to be non-business related

HTTP Tunneling: Is applied not to circumvent security, but rather to “enhance” functionality. It is used to bypass user restrictions, and allow an application to function through a firewall. Usually tunneling is applied by encapsulating outgoing traffic from an application in an HTTP request and incoming traffic in a response. **Countermeasures:** Filtering on firewall or proxy server. However, the security officer must balance business value and effectiveness of the countermeasures.

Secure Shell (SSH)

Secure Shell (SSH): SSH is the secure alternative for users that wish to log on to a remote computer. Unlike TELNET, RSH, and rlogin, it allows users to securely access (remote) resources over an encrypted tunnel. SSH services include remote log-on, file transfer, command execution, and port forwarding. It ensures integrity, preventing session hijacking or other MITM attacks, and supports strong authentication.

IPSec Authentication and Confidentiality for VPNs

IP Security (IPSec) is a suite of protocols for communicating securely over IP, providing mechanisms for authentication and encryption. It is mandatory in IPv6, but also often implemented in IPv4. IPSec provides mutual host authentication; for *user* authentication organization can use IPSec over L2TP (Layer 2 Tunneling Protocol). IPSec is not compatible with NAT, so NAT-Traversal (NAT-T) was devised, encapsulating IPSec within UDP/4500.

- **Authentication Header (AH):** The AH ensures integrity (i.e., proof of sender's identity and non-tampered data), by transmitting before each packet a hash value of the packet's contents, based on a shared secret.
- **Encapsulating Security Payload (ESP):** ESP can both encrypt IP packets and ensure their integrity.
 - **ESP header:** Information about the security association, and sequence number.
 - **ESP payload:** Encrypted part of the packet, IV (Initialization Vector) if used. Most of the times symmetric encryption is used.
 - **ESP trailer:** Padding, Next header.
 - **Authentication:** Integrity check value (hash) of the ESP packet.
- **Security Associations (SA):** An SA defines the mechanisms that an endpoint will use to communicate with its partner. It concerns only one direction, so for two-way communication 2 SAs must be defined. The aforementioned mechanisms include the encryption and authentication algorithms, and whether to use the AH or ESP protocol.
- **Transport Mode and Tunnel Mode:** In transport mode, the IP payload is protected; mostly used for end-to-end protection. In tunnel mode, the IP payload and its header are protected; often used between networks, such as firewall-to-firewall VPNs.
- **Internet Key Exchange (IKE):** Used to prove identity of each other (i.e., authentication component of IPSec). It works in two phases:
 - **Phase 1** - Authenticate with each other using one of the following:
 - Shared Secret
 - Public Key Encryption
 - Revised Mode of Public Key EncryptionThen, IKE establishes a temporary SA and secure tunnel to protect the rest of the key exchange.
 - **Phase 2** - The actual SAs are established using the secure channel and temporary SA

3. Network Attacks

Scanning Techniques

- **Port Scanning:** probing for TCP services on a machine. It is performed by establishing the initial handshake for connection. It is not an attack in itself, but allows for identifying potentially vulnerable services on a target system.
- **FIN, NULL, and XMAS Scanning:** FIN is a stealth scanning method, where a request to close a connection is sent to the target machine. If no application is listening to that port a TCP RST or ICMP packet will be sent, revealing an open port. There are firewalls available that put the system into stealth mode (preventing the aforementioned attack from happening). Similarly, with NULL scanning, no flags are set on the initiating TCP packet, while with XMAS scanning all flags are set on the initiating TCP packet.

IP Fragmentation Attacks and Crafted Packets

- **Teardrop:** IP packet fragments are constructed so that the target host calculates a negative fragment length, when attempting to reconstruct the packet, resulting in the host to crash.
- **Overlapping Fragment Attack:** Used to subvert packet filters that only inspect the first fragment of a fragmented packet, by sending a harmless first fragment and then overwriting it. A solution would be for TCP/IP stacks to not allow fragment overwriting.
- **Source Routing Exploitation:** Source routing allows the sender to explicitly specify the path of an IP packet, instead of letting the router do it. This can be exploited by an attacker, giving him/her access to an internal network. The best solution is to disable source routing at hosts and block source-routed packets.
- **Smurf and Fraggle Attacks:** They are both denial-of-service attacks. In a Smurf attack the intruder broadcasts an ICMP echo request with a spoofed source address of the victim. Then, the victim gets overwhelmed by all the ICMP echo replies, resulting in denial of service. Similarly, a Fraggle attack broadcasts UDP packets on port 7, resulting in a denial of service, caused by the responses of the network.
- **NFS Attacks:** NFS attacks are exploiting security vulnerabilities, especially on versions 2 and 3, mainly due to their rather basic authentication mechanisms and the publication of file system trees from the server. Within this tree the privileges of the server file system will be mapped to client users. The points of risk include:
 - Exporting parts of the file system that were not intended for publication.
 - Using an unauthorized client. NFS is only based on IP, so it is relatively easy to masquerade an authorized user by IP or DNS spoofing.
 - Incorrect mapping of user IDs between server and client. NFS relies solely on user IDs for authorization credentials. Thus, an attacker that has obtained administrative access to a client can generate arbitrary user IDs matching those on the server.
 - Sniffing and access request spoofing. NFS traffic is by default not encrypted. It can be therefore intercepted, and used to access files if the appropriate access token has

been obtain. Note that NFS does not authenticate each RPC call, while the secure version of it (SNFS) does.

- SetUID files. On UNIX systems files with the SUID bit can therefore be used for privilege escalation on the client.

Denial-of-Service Attack

A DoS attack is basically overloading a network with excessive traffic, so as to shut it down, or render it useless, by significantly slowing it down. Some countermeasures are:

- Multiple layers of firewalls
- Careful filtering at firewalls, routers and switches
- Internal NAC (Network Access Controls)
- Redundant connections
- Load balancing
- Getting help from upstream service providers

Distributed Denial-of-Service Attack

DDoS is one way of deploying a DoS attack, using a network of remote-controlled hosts known as botnets. This is harder to detect and block, as simple IP or port filtering might not work.

SYN Flooding

A SYN flood is a type of denial-of-service attack against the initial handshake in a TCP connection. Many connections from faked, random IP addresses are opened in short order, overloading the target's connection table.

Spoofing

IP Address Spoofing and SYN-ACK Attacks

Packets are sent with a bogus source address so that the victim will send a response to a different host. Spoofed addresses may be used to abuse the TCP handshake. The attacker sends a storm of SYN packets with faked addresses, then the victim will send out many SYN+ACK packets and receive no final ACK responses, as the IP addresses are fake. This results in the victim reaching the limit of half-open handshakes, refusing other legitimate network connections.

E-mail Spoofing

E-mail spoofing is very simple over SMTP, as there is no adequate authentication mechanism. It can be done by sending a TELNET command on port 25 of a mail server, and a few SMTP commands. E-mail spoofing is often used to obfuscate the sender's identity in spamming.

DNS Spoofing

To resolve a domain name the user's workstation has to undertake a series of queries through the DNS hierarchy. There are two types of queries:

- Recursive, where the name server receiving it will forward it and return the resolution, and
- Iterative, where the name server receiving it will respond with a reference

A common attack, called DNS poisoning is carried out by injecting fake records in the name server's cache. The attacker first queries the target DNS server, and waits until it sends out a query for resolution. In the case of recursive queries, the attacker sends a query for a domain, whose primary name server he controls. Additional information is now cached at the DNS. In the case of iterative queries, using IP spoofing, the attacker sends a response to his own query before the correct name server has a chance to respond. In both cases the attacker can inject false information into the DNS server's cache, which will –even worse– propagate to other DNS servers, due to the way DNS resolution works. DNSSEC can overcome some of the related vulnerabilities, offering authentication, but it has not found wide acceptance. The ultimate solution for organizations would be to establish their own DNS servers, dedicated to their domains.

Manipulation of DNS Queries

Pharming is the manipulation of DNS records

1. By manipulating the hosts (aka etc) file on a workstation, or
2. By compromising the DNS server itself.

Social engineering can also play a role in making users misinterpret a DNS address that is presented to them through a phishing e-mail.

4. Firewalls

A firewall is a network security system that monitors and controls incoming and outgoing traffic based on predefined security rules, acting as a barrier between trusted and untrusted networks. The main types of firewalls include:

- **Packet-Filtering Firewalls** are network security devices that control the flow of data packets into and out of a network based on predefined rules, such as IP addresses and port numbers. It allows or blocks packets based on these rules, helping to protect the network from unauthorized access and manage traffic efficiently.
 - **Advantages:**
 - Powerful protection for entire network: filtered packets never reach devices → Significantly reduce attack surface
 - Simple rule matching → very efficient
 - Widely available, many resources: documentation, GUIs...

- **Disadvantages:**
 - Usability: firewall cannot block everything → Possible to hide traffic as different protocol/port
 - Bugs in rules
 - Need to balance protection and rule complexity → e.g., whitelisting every single authorized IP
 - Only works if traffic transits through firewall → e.g., using mobile data instead of WiFi
- **Proxy Firewall** is a network security device that acts as an intermediary between users and the internet, filtering messages and data at the application layer. It enhances security by preventing direct connections between internal networks and external services, thus protecting internal IP addresses and controlling access to web resources. Proxy firewalls can be explicit, or transparent, in which latter case one of the communicating devices is unaware of that there is a firewall in between.
 - **Advantages and Disadvantages:**

Application knowledge

 - + Logging → accountability
 - + Caching → bandwidth reduction
 - + More intelligent filtering
 - Application-specific

+ Aggregation of clients under same endpoint → anonymity

 - Complex: can degrade performances
 - Usually requires specific setup for one end of connection

+ Allows controlled connections to a service without service needing to implement authentication (e.g., SOCKS proxy)

 - Need to trust proxy with handling sensitive data
 - Basically, an authorized man-in-the-middle attack
 - HTTP caching proxies much less common nowadays

Tiered Architecture

In practice, we usually try to combine techniques to get the best of all worlds (to the extent possible). As such, we partition our network into different domains of trust, based on the security policies, and we apply multiple levels of firewalls and protections (based on risk-informed decisions).

- **Demilitarized Zone (DMZ):** A DMZ (or screened subnet) allows giving external hosts limited access to resources. DMZs are typically isolated subnets attached to a firewall. This configuration (with the three interfaces - internal, external and DMZ) is called three-legged firewall. Organizations should only put non-sensitive information in a DMZ, as it is designed for external hosts.

- **Internal network:** connections need to come from DMZ: server to DB or user authenticating through bastion
 - need to go through multiple service before getting to internal (important machines) and principle of least privilege
 - Hence why having internal access (hacking employee) is so powerful!

5. Intrusion Detection Systems

Intrusion Detection Systems (IDSs) monitor activity and send alerts when they detect suspicious traffic or activity. IDSs are divided into two broad classes, based on the origin of the monitored events:

- Host-based IDSs (HIDS) monitoring activity on servers and workstations, and
- Network-based IDSs (NIDS) monitoring network activity.

Unlike Intrusion Prevention Systems (IPSs), IDSs are passive monitoring tools. They collect real-time information, when suspicious activities are identified, and present this information in the form of a warning/alarm to the incident-response personnel monitors.

An IPS monitors activity, just like an IDS, and on top of that it automatically takes proactive preventative action if it detects unacceptable activity. IPSs work also in real-time, and they are considered an access control and policy enforcement technology, due to their proactive nature. To the contrary, IDSs are considered network monitoring and auditing technology.

IDS Analysis Engine Methods:

- **Signature-Based Detection:**
 - Stateful Matching Intrusion Detection takes pattern matching to the next level. It scans for attack signatures in the context of a stream of traffic or overall system behavior rather than the individual packets or discrete system activities.
 - **Advantages:**
 - Fast
 - Accurate
 - Signatures can be shared: learn from others
 - **Disadvantages:**
 - Signatures need to be updated by somebody
 - Malicious actors try to obfuscate their signatures
- **Anomaly-Based Detection:**
 - Statistical-anomaly-based systems establish a baseline of normal traffic patterns over time and detect any deviations from that baseline. Some also use heuristics to evaluate the intended behavior of network traffic to determine if it intended to be malicious or not.
 - Protocol-anomaly-based systems examine network traffic to determine if what it sees conforms to the defined standard for that protocol; for example, as it is defined in a Request for Comment or RFC.

- Traffic Anomaly-Based Intrusion Detection identifies any unacceptable deviation from expected behavior based on actual traffic structure. When a session is established between systems, there is typically an expected pattern and behavior to the traffic transmitted in that session. That traffic can be compared to expected traffic conduct based on the understandings of traditional system interaction for that type of connection.
- **Advantages:**
 - Detects “never seen before” attacks
 - “Automatic” learning
- **Disadvantages:**
 - Difficult to configure:
 - Selecting features
 - Ensure intruder-free training
 - Usual problems of training a ML/anomaly detection model → tradeoffs
 - Legitimate users can behave abnormally → false positives

6. Base Rate (Fallacy)

Base rate in intrusion detection refers to the frequency of legitimate events in a given dataset, which is crucial for understanding the context of alerts generated by intrusion detection systems. A low base rate can lead to a high number of false positives, making it challenging to distinguish between normal and malicious activity.

We can adjust the sensitivity of IDSs (usually) both during training and during operation:

- Can be made more sensitive → better detection but false positives
- Can be made less sensitive → might miss some malicious activity

Bayes' Theorem

$$P(A|B) = \frac{P(B|A)P(A)}{P(B)}$$